

Kryptographie

Von Caesar bis Post- Quantum

Agenda

- **Grundlagen & Begriffe** – Was ist Krypto, Kerckhoffs, Sym vs. Asym
- **Klassische Verfahren** – Caesar, Vigenère, Kryptoanalyse
- **Exkurs Enigma** – Geniale Maschine, fatale Schwächen
- **Symmetrisch heute** – AES & warum der Modus zählt
- **Schlüsselaustausch & Asymmetrie** – Diffie-Hellman, RSA
- **Kryptographie in der Praxis** – Hybrid, Hashes, Signaturen, PKI
- **Ausblick** – Post-Quantum-Kryptographie

Grundlagen & Begriffe

Worum geht es eigentlich?

Kryptographie vs. Kryptoanalyse

- **Kryptographie:** Wissenschaft vom *Entwerfen* sicherer Verfahren
 - Ziel: Nachrichten so schützen, dass Unbefugte sie nicht lesen/verändern können
- **Kryptoanalyse:** Wissenschaft vom *Brechen* dieser Verfahren
 - Ziel: Schwächen finden, Klartext ohne Schlüssel rekonstruieren
- **Kryptologie:** Oberbegriff für beide Disziplinen

Merksatz: Gute Kryptographie entsteht nur im ständigen Wettstreit mit der Kryptoanalyse.

Ein paar Grundbegriffe

- Klartext (plaintext): die lesbare Ausgangsnachricht
- Geheimtext (ciphertext): die verschlüsselte, unlesbare Form
- Verschlüsseln / Entschlüsseln: Umwandlung in beide Richtungen
- Schlüssel (key): geheime Information, die den Vorgang steuert
- Chiffre (cipher): der Algorithmus/das Verfahren selbst



Was Kryptographie leisten soll

Vier Schutzziele – direkte Verbindung zur CIA-Triade:

- **Vertraulichkeit:** Nur Befugte können mitlesen (*Confidentiality*)
- **Integrität:** Manipulation wird erkannt (*Integrity*)
- **Authentizität:** Der Absender ist wirklich, wer er vorgibt
- **Nicht-Abstreitbarkeit:** Handlungen sind nachweisbar zurechenbar

Verschlüsselung schützt Vertraulichkeit – aber Integrität, Authentizität & Zurechenbarkeit brauchen *zusätzliche* Bausteine (Hashes, Signaturen).

Ausblick: AES und RSA sind hier nur Namen für Beispiele; ihre Funktionsweise folgt in späteren Kapiteln.

Kerckhoffs' Prinzip (1883)

- **Kernaussage:** Die Sicherheit eines Verfahrens darf **nur vom Schlüssel** abhängen – nicht von der Geheimhaltung des Algorithmus.
- Der Algorithmus darf öffentlich bekannt sein, ohne dass die Sicherheit leidet.
- **Gegenteil:** „Security by Obscurity“ – Sicherheit durch Verschleierung

Shannon's Maxime: „Der Feind kennt das System.“

Symmetrisch vs. Asymmetrisch

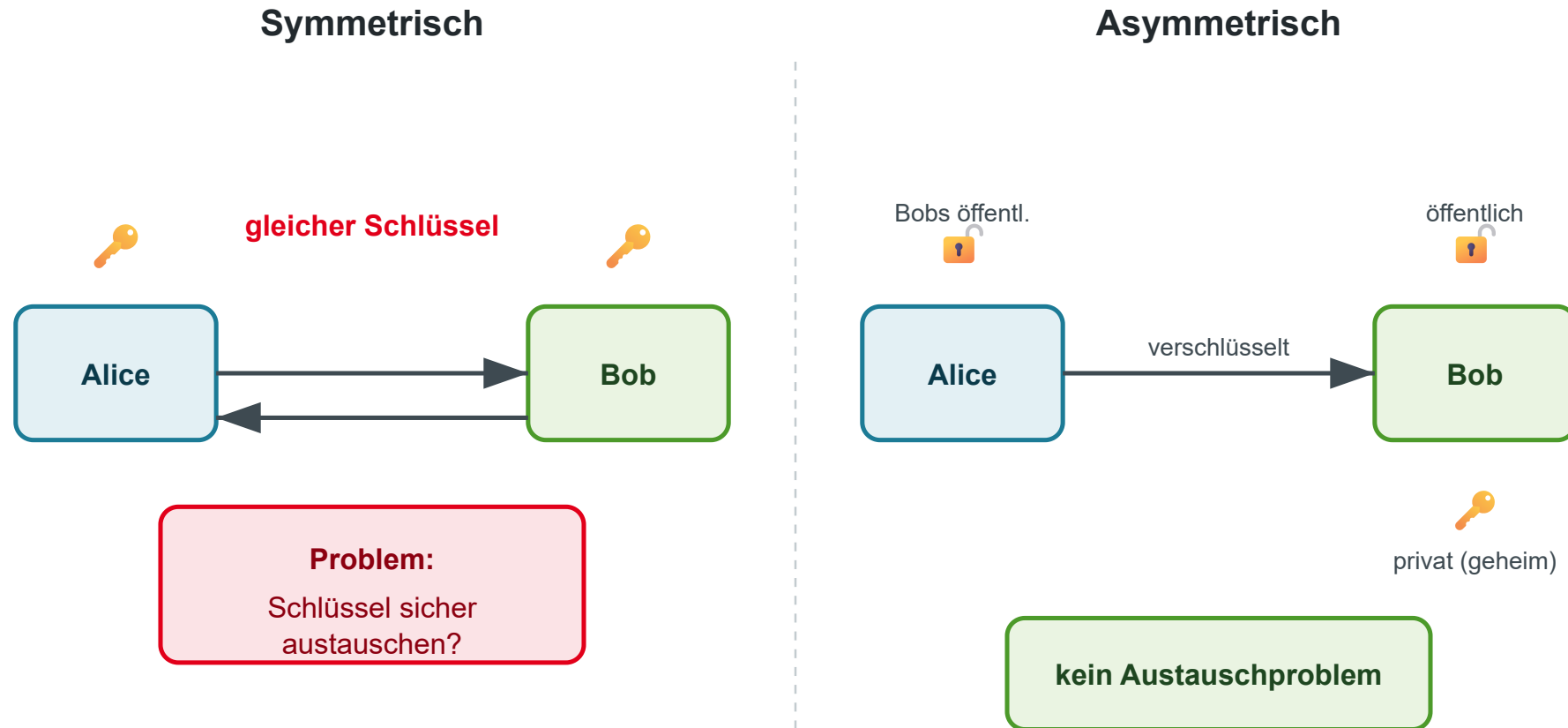
Symmetrisch

- Ein gemeinsamer Schlüssel
- Ver- und Entschlüsseln mit demselben Geheimnis
- Sehr **schnell**
- Problem: Wie tauscht man den Schlüssel sicher aus?
- Beispiel: **AES**

Asymmetrisch

- **Schlüsselpaar**: öffentlich + privat
- Öffentlicher verschlüsselt, privater entschlüsselt
- Deutlich **langsamer**
- Löst das Austauschproblem
- Beispiel: **RSA**

Symmetrisch vs. Asymmetrisch – Bild



Klassische Verfahren

Wie alles begann

Die Caesar-Chiffre

- Jeder Buchstabe wird um eine **feste Zahl** verschoben
- Julius Caesar nutzte eine Verschiebung um 3

$$A \rightarrow D, \quad B \rightarrow E, \quad C \rightarrow F \dots$$

- **Beispiel** (Verschiebung 3):
 - Klartext: HALLO
 - Geheimtext: KD00R
- **Schlüssel**: die Verschiebung (nur 25 sinnvolle Möglichkeiten!)

Monoalphabetische Substitution

- Statt fester Verschiebung: **jeder Buchstabe** wird durch einen beliebigen anderen ersetzt
- Schlüsselraum: $26! \approx 4 \times 10^{26}$ Möglichkeiten – riesig!
- **Trotzdem leicht zu brechen. Warum?**
 - Die Struktur der Sprache bleibt erhalten
 - Häufige Buchstaben bleiben häufig – nur unter anderem Namen

Kryptoanalyse: Häufigkeitsanalyse

- Jede Sprache hat eine **typische Buchstabenverteilung**
- Im Deutschen: **E** ist mit Abstand am häufigsten (~17 %), dann N, I, S, R
- Der häufigste Buchstabe im Geheimtext ist also vermutlich das **E**
- **Vorgehen:**
 - Buchstaben im Geheimtext zählen
 - Mit bekannter Sprachstatistik abgleichen
 - Schritt für Schritt das Alphabet rekonstruieren

Erstmals dokumentiert vom Gelehrten **al-Kindī** (9. Jh.) – die Geburt der Kryptoanalyse.

Die Vigenère-Chiffre

- **Idee:** Verschiebung wechselt pro Buchstabe – gesteuert durch ein **Schlüsselwort**
- Gilt lange als „le chiffre indéchiffrable“ (die unknackbare Chiffre)
- **Beispiel** mit Schlüssel **KEY**:

Klartext	H	A	L	L	O
Schlüssel	K	E	Y	K	E
Geheimtext	R	E	J	V	S

- Gleicher Klartextbuchstabe → **unterschiedliche** Geheimtextbuchstaben

Auch Vigenère fällt

- **Schwäche:** Das Schlüsselwort **wiederholt sich** periodisch
- Findet man die **Schlüssellänge**, zerfällt Vigenère in mehrere *Caesar*-Chiffren
- Jede davon ist per Häufigkeitsanalyse angreifbar
- **Kasiski-Test (1863):** Wiederkehrende Muster im Geheimtext verraten die Schlüssellänge

Lehre: „Unknackbar“ bedeutet meist nur „noch nicht geknackt“.

Mini-Beispiel: Wiederholen sich auffällige Zeichenfolgen im Abstand von 6 und 12 Zeichen, ist eine Schlüssellänge von 3 oder 6 ein möglicher Kandidat.

Exkurs: Die Enigma

Geniale Maschine, fatale Schwächen

Enigma – Kontext & Bedeutung

- Deutsche Rotor-Chiffriermaschine, im **2. Weltkrieg** militärisch eingesetzt
- Elektromechanische Umsetzung einer **polyalphabetischen** Chiffre
- Galt als praktisch unknackbar – Schlüsselraum von rund 10^{23}
- Ihr Bruch durch die Alliierten hatte **kriegsentscheidende** Bedeutung

Enigma – Tagesschlüssel

- Sicherheit hing an der **Grundeinstellung** (dem „Tagesschlüssel“):
 - Auswahl & Reihenfolge der Walzen
 - Startposition jeder Walze
 - Steckerbrett-Verbindungen
- Verteilt über **gedruckte Codebücher** an alle Funkstellen
- Schlüsselwechsel täglich um Mitternacht

Kerckhoffs in Reinform: Die Maschine war den Alliierten bekannt – geheim war nur der Tagesschlüssel.

Enigma – Die Schwächen

- **Konstruktionsfehler Reflektor:** Kein Buchstabe konnte auf sich selbst abgebildet werden
 - Ein A wurde nie zu einem A → wertvoller Ansatzpunkt für Angreifer
- **Bedienfehler:**
 - Vorhersehbare Nachrichten („Wetterbericht“, „Keine besonderen Vorkommnisse“)
 - Wiederholte Standardfloskeln als **Cribs** (vermutete Klartextstücke)
 - Schwache, wiederholte Spruchschlüssel der Funker
- **Menschliche Routine** unterlief die geniale Technik

Enigma – Bletchley Park & Turing

- Britisches Entschlüsselungszentrum **Bletchley Park**
- **Alan Turing** entwickelte die elektromechanische „**Bombe**“
 - Testete systematisch Rotorstellungen und schloss Widersprüche aus
 - Nutzte Crips, um den Suchraum drastisch zu verkleinern
- Vorarbeiten polnischer Mathematiker (u. a. **Marian Rejewski**)
- Ergebnis: „**Ultra**“ – ein entscheidender alliierter Nachrichtenvorteil

Enigma – Was wir lernen

- **Kerckhoffs bestätigt:** Sicherheit lag im Schlüssel, nicht in der geheimen Maschine
- **Komplexität $\neq$ Sicherheit:** 10^{23} Kombinationen halfen nicht gegen kluge Angriffe
- **Der Mensch ist das Risiko:** Bedienfehler brachen die Chiffre, nicht die Mathematik
- **Bekannter Klartext ist gefährlich:** Crips sind ein realer Angriffsvektor – bis heute

Symmetrische Verschlüsselung

heute

Der Standard: AES

AES – Advanced Encryption Standard

- **2001** vom US-Institut NIST standardisiert (Vorgänger: DES)
- Gewinner eines **offenen, öffentlichen** Wettbewerbs (Algorithmus „Rijndael“)
- **Blockchiffre**: verschlüsselt Daten in Blöcken zu 128 Bit
- Schlüssellängen: **128, 192 oder 256 Bit**
- Weltweiter Standard: TLS, VPN, WLAN (WPA2/3), Festplatten, Messenger

Vor dem Modus: Längere Nachrichten bestehen aus mehreren 128-Bit-Blöcken. Ein Betriebsmodus legt fest, wie diese Blöcke zusammen verarbeitet werden.

AES – warum so vertrauenswürdig?

- **Offen & geprüft:** Über 20 Jahre weltweite Kryptoanalyse ohne praktischen Bruch
- **Schnell:** Moderne CPUs haben AES in Hardware eingebaut (AES-NI)
- **Skalierbar:** 128 Bit für fast alles, 256 Bit für höchste Ansprüche
- **Brute Force chancenlos:** 2^{128} Schlüssel – astronomisch groß

Das Schlüsselverteilungsproblem

- AES ist schnell und sicher – aber **beide Seiten brauchen denselben Schlüssel**
- Wie kommt der Schlüssel sicher zum Empfänger?
 - Persönlich übergeben? Unpraktisch bei Millionen Nutzern
 - Über das Internet schicken? Dann kann ihn jeder abfangen
- Bei n Teilnehmern: $\frac{n(n-1)}{2}$ Schlüssel nötig
 - 1.000 Nutzer $\rightarrow$ ~ 500.000 Schlüssel

Das zentrale Dilemma der symmetrischen Kryptographie.

Schlüsselaustausch & Asymmetrie

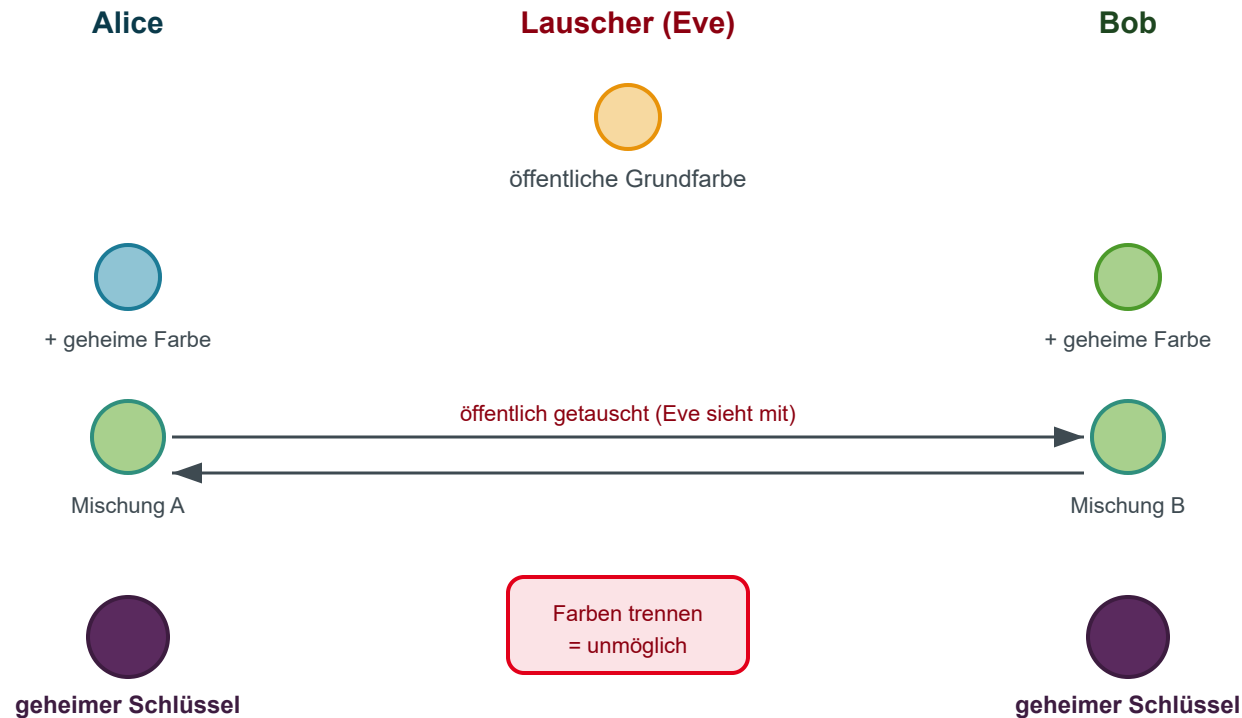
Der Durchbruch der 1970er

Diffie-Hellman – die Idee

- **Problem gelöst 1976:** Zwei Parteien vereinbaren über einen **öffentlichen** Kanal einen **gemeinsamen geheimen** Schlüssel
- Ein Lauscher, der alles mithört, kann das Geheimnis **trotzdem nicht** berechnen
- Grundlage: eine mathematische **Einwegfunktion** (leicht vorwärts, praktisch unmöglich rückwärts)

Kein Schlüssel wird je übertragen – er wird auf beiden Seiten **berechnet**.

Diffie-Hellman – die Farb-Analogie



- Öffentliche Farbe + je eine **geheime** Farbe → gemischt ausgetauscht
- Beide mischen ihre geheime Farbe dazu → **identische** Endmischung
- Lauscher sieht nur die Mischungen – **Farben trennen ist unmöglich**

Asymmetrische Kryptographie – das Prinzip

- **Schlüsselpaar** pro Person: öffentlicher + privater Schlüssel
- Mathematisch verbunden, aber der private lässt sich **nicht** aus dem öffentlichen berechnen
- **Öffentlicher Schlüssel**: darf jeder kennen (verschlüsselt Nachrichten an mich)
- **Privater Schlüssel**: bleibt geheim (nur ich kann entschlüsseln)

Briefkasten-Analogie: Einwurf kann jeder (öffentlich), leeren nur der Besitzer (privat).

RSA – die Grundidee

- Benannt nach **Rivest, Shamir, Adleman** (1977)
- Sicherheit beruht auf: **Zwei große Primzahlen multiplizieren ist leicht – das Produkt wieder zerlegen ist praktisch unmöglich**
- Vereinfacht:
 - Verschlüsseln mit öffentlichem Schlüssel: $c = m^e \bmod n$
 - Entschlüsseln mit privatem Schlüssel: $m = c^d \bmod n$
- Das große n (Produkt zweier Primzahlen) ist öffentlich – seine **Faktoren** sind das Geheimnis

RSA – wofür man es nutzt

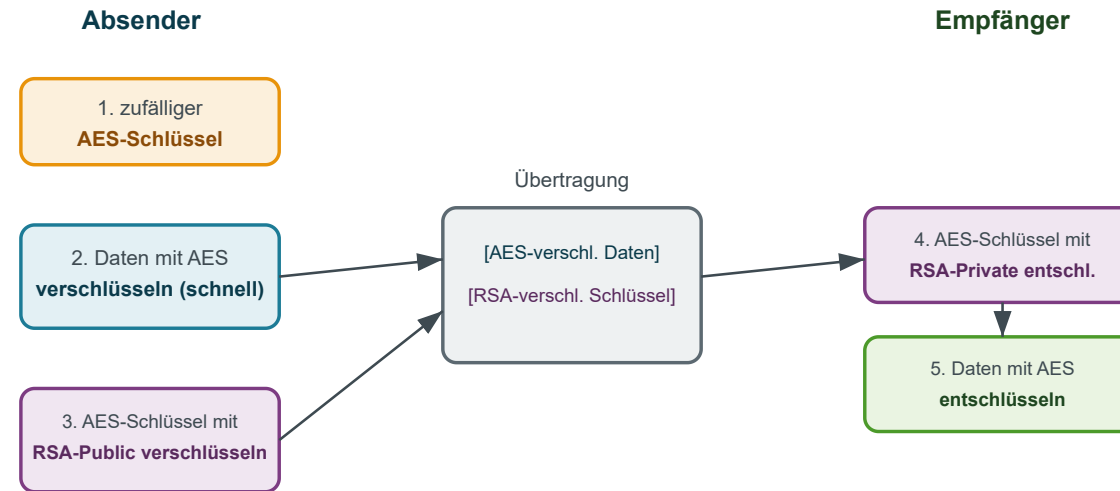
- **Verschlüsselung** kleiner Datenmengen (z. B. eines AES-Schlüssels)
- **Digitale Signaturen** (dazu gleich mehr)
- **Langsam** im Vergleich zu AES → nicht für große Datenmengen geeignet

Konsequenz: In der Praxis kombiniert man beide Welten → **hybride Verschlüsselung**.

Kryptographie in der Praxis

So funktioniert es wirklich

Hybride Verschlüsselung



- **Asymmetrisch** (RSA/DH) transportiert sicher einen zufälligen **AES-Schlüssel**
- **Symmetrisch** (AES) verschlüsselt dann die eigentlichen Daten – schnell

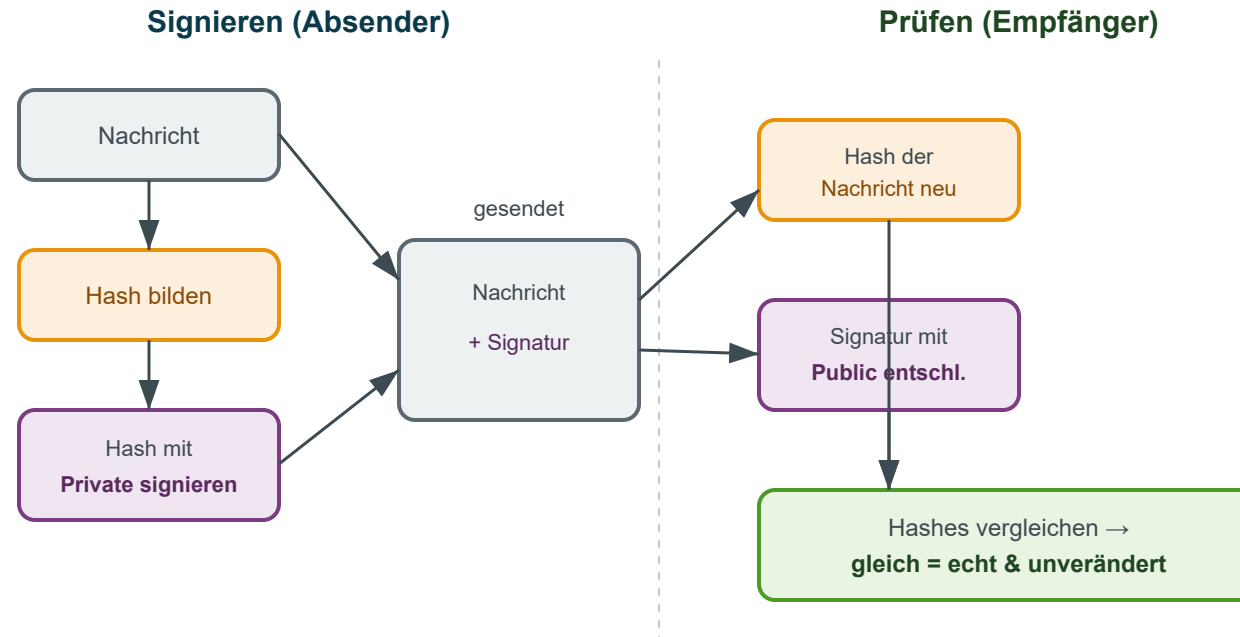
Das Beste aus beiden Welten: Sicherheit des Austauschs + Geschwindigkeit von AES.

Kryptographische Hashfunktionen

- Bilden beliebig lange Daten auf einen **festen, kurzen** Wert ab (den „Fingerabdruck“)
- **Einwegfunktion**: aus dem Hash lässt sich das Original nicht rekonstruieren
- Kleinste Änderung am Input → **völlig anderer** Hash (Lawineneffekt)
- **Kollisionsresistent**: kaum zwei Eingaben mit gleichem Hash
- Standards: **SHA-256, SHA-3** (nicht mehr: MD5, SHA-1 – gebrochen)

Anwendung: Integritätsprüfung, Passwortspeicherung, Signaturen, Blockchain.

Digitale Signaturen



- **Signieren:** Hash der Nachricht mit dem **privaten** Schlüssel verschlüsseln
- **Prüfen:** Empfänger vergleicht mit dem **öffentlichen** Schlüssel
- Umgekehrte Nutzung der Asymmetrie: privat signiert, öffentlich prüft

Signaturen – welche Ziele werden erfüllt?

- **Integrität:** jede Änderung ändert den Hash → Signatur passt nicht mehr
- **Authentizität:** nur der Inhaber des privaten Schlüssels konnte signieren
- **Nicht-Abstreitbarkeit:** der Absender kann die Signatur nicht leugnen

Verschlüsselung schützt Vertraulichkeit – **Signaturen** schützen Integrität, Authentizität & Zurechenbarkeit.

Das Vertrauensproblem: PKI

- Woher weiß ich, dass ein **öffentlicher Schlüssel** wirklich der richtigen Person gehört?
- Gefahr: Ein Angreifer schiebt **seinen** Schlüssel unter (Man-in-the-Middle)
- **Public Key Infrastructure (PKI)**:
 - **Zertifikate** binden einen Schlüssel an eine Identität
 - **Certificate Authority (CA)**: vertrauenswürdige Stelle, die Zertifikate signiert
 - Browser vertrauen einer Liste bekannter CAs

Das **Schloss-Symbol** im Browser = ein gültiges, von einer CA signiertes Zertifikat.

Ausblick

Post-Quantum-Kryptographie

Die Quanten-Bedrohung

- **Quantencomputer** nutzen andere Rechenprinzipien als klassische Rechner
- Der **Shor-Algorithmus** könnte Faktorisierung & diskreten Logarithmus effizient lösen
- **Betroffen:** RSA und Diffie-Hellman wären damit gebrochen
- **Weniger betroffen:** AES (längere Schlüssel genügen) und Hashfunktionen

„Harvest now, decrypt later“: Verschlüsselte Daten werden heute schon gesammelt, um sie später zu entschlüsseln.

Post-Quantum-Kryptographie (PQC)

- Neue Verfahren, die auch **Quantencomputern** standhalten
- Basieren auf anderen mathematischen Problemen (z. B. **Gitter / Lattices**)
- **NIST** hat 2024 erste Standards veröffentlicht (u. a. **ML-KEM / Kyber**)
- Laufen auf **klassischen** Computern – kein Quantencomputer nötig
- Migration hat begonnen (Browser, Messenger, VPNs)

Kryptographie ist nie „fertig“ – sie entwickelt sich mit den Angriffen weiter.

Einordnung: ML-KEM ist ein standardisiertes Verfahren zum Vereinbaren eines gemeinsamen Geheimnisses; „Kyber“ bezeichnet die zugrunde liegende Verfahrensfamilie.

Zusammenfassung

Baustein	Typ	Schützt vor allem
AES	Symmetrisch	Vertraulichkeit (schnell, Massendaten)
Diffie-Hellman	Asymmetrisch	Sicherer Schlüsselaustausch
RSA	Asymmetrisch	Schlüsseltransport & Signaturen
Hashfunktion	Einweg	Integrität (Fingerabdruck)
Digitale Signatur	Asymmetrisch	Authentizität, Integrität, Zurechenbarkeit
PKI / Zertifikate	Infrastruktur	Vertrauen in öffentliche Schlüssel

Die zeitlosen Lehren

- **Kerckhoffs' Prinzip:** Sicherheit steckt im Schlüssel, nicht im Geheimnis des Verfahrens
- **Offenheit schafft Vertrauen:** Nur öffentlich geprüfte Verfahren sind vertrauenswürdig
- **Der Mensch ist oft die Schwachstelle** – nicht die Mathematik
- **Richtige Anwendung zählt:** Der beste Algorithmus versagt im falschen Modus
- **Kryptographie ist ein Wettlauf** – sie entwickelt sich immer weiter

Diskussion

- Sollten Behörden **Hintertüren** in Verschlüsselung fordern dürfen?
- Wie geht ihr im Alltag mit **Ende-zu-Ende-Verschlüsselung** um?
- Wo begegnet euch Kryptographie in eurem **Unternehmen**?